

等级保护2.0在金融行业的发展和展望

■ 中国人民银行青岛市中心支行 曹希真

摘要：本文介绍了等级保护制度的发展历程，对比了等级保护2.0与1.0版本的区别，阐述了等级保护制度在金融行业的应用现状，并对等级保护2.0在金融行业的落实提出了意见建议——加强网络安全制度体系的学习、转变网络安全治理理念、重视网络安全新技术的应用。

关键词：金融科技；等级保护2.0；现状；建议

一、等级保护制度的发展历程

1994年，国务院147号令《中华人民共和国计算机信息系统安全保护条例》首次提出了信息安全等级保护的概念，即对国家秘密信息及公民、法人和其他组织的专有信息、公开信息，以及存储、传输、处理这些信息的信息系统分等级实行安全保护。1999年发布的国家标准GB17859-1999《计算机信息系统安全保护等级划分准则》，首次明确了等级保护分为5个等级。2007年，《信息安全等级保护管理办法》（公通字〔2007〕43号）正式发布，规定了等级保护制度的基本内容、工作流程及工作要求等，为开展信息安全等级保护工作提供了依据。2017年，《中华人民共和国网络安全法》正式实施，规定“国家实行网络安全等级保护制度，网络运营者应当按照网络安全等级保护制度的要求，履行安全保护义务”，这代表着等级保护工作正式上升为国家法律

层面的要求。

为适应新技术的快速发展，2019年5月13日，国家标准新闻发布会召开，发布了更新版的网络安全等级保护制度2.0标准，要求于2019年12月1日起正式实施等级保护2.0相关的《信息安全技术网络安全等级保护基本要求》《信息安全技术网络安全等级保护测评要求》《信息安全技术网络安全等级保护安全设计技术要求》等国家标准。

二、等级保护2.0的主要变化

（一）名称变化

为适应新环境下网络安全工作要求，在等级保护2.0中，信息安全等级保护正式更名为网络安全等级保护，与国家《网络安全法》相关说法保持了一致。

根据国际标准化组织的定义，信息安全是指信息

作者简介：曹希真（1986-），女，山东青州人，工学硕士，工程师，供职于中国人民银行青岛市中心支行，主任科员，研究方向：网络管理与网络安全。

收稿日期：2020-01-20



在生产、传输、处理和储存过程中不被泄露或破坏，确保信息的可用性、保密性、完整性和不可否认性，并保证信息系统的可靠性和可控性；而根据《网络安全法》的定义，网络安全是指通过采取必要措施，防范针对网络的攻击、侵入、干扰、破坏、非法使用和意外事故，使网络处于稳定可靠运行的状态，以及保障网络数据的完整性、保密性、可用性的能力。从定义上看，网络安全包含于信息安全，可以理解为网络环境下的信息安全，故将名称由信息安全等级保护改为网络安全等级保护也更加精确。

（二）保护对象的变化

等级保护1.0的保护对象为网络和信息系统，而在等级保护2.0时代，为了进一步适应新技术的发展，等级保护对象增加了基础信息网络、云计算平台、大数据平台、物联网系统、工业控制系统、采用移动互联技术的网络等。保护对象的进一步明确和扩展，也符合技术发展的要求。

（三）安全要求的变化

等级保护1.0中针对测评对象主要提出了各种安全要求，包括管理和技术两方面的控制措施。在等级保护2.0中，安全要求仅作为基础的通用要求，规定了所有等级保护对象必须满足的要求。在此基础上，等级保护2.0新增了针对特定保护对象的安全扩展要求，主要包括云计算安全扩展要求、移动互联安全扩展要求、物联网安全扩展要求、工业控制系统安全扩展要求等，以更好地满足信息技术新形势下的网络安全需要。

（四）控制措施的变化

等级保护1.0的控制措施，主要包括管理措施和技术措施。其中，管理措施包括安全管理制度、安全管理机构、人员安全管理、系统建设管理、系统运维管理5个方面，技术措施包括物理、网络、主机、应用、数据等方面。

在等级保护2.0中，管理部分五大类依次变为安全

管理制度、安全管理机构、安全管理人员、安全建设管理、安全运维管理，与1.0无太大的变化。但技术措施方面则进行了较大的变更，强调了“一个中心、三重防护”的网络安全技术设计架构。“一个中心”指的是安全管理中心，“三重防护御”指的是安全计算环境、安全区域边界、安全通信网络，再加上安全物理环境，共同构成了等级保护2.0的技术控制措施。

（五）工作流程的变化

等级保护1.0规定了5步工作流程，包括定级、备案、整改、测评、监督检查。等级保护2.0延续了这5个流程，并进行部分修改。值得关注的是，在定级原则上，等级保护2.0放弃了1.0中的“自主定级、自主保护”原则；定级流程中增加了主管部门审核的要求，实现了以国家行政机关持续监督的“明确等级、增强保护、常态监督”定级原则，这更能有效地保障等级保护制度的顺利落实。另外，等级保护2.0在以上5个规定动作上，还将风险评估、安全监测、通报预警、态势感知等安全相关的工作纳入了等级保护制度要求中，使得该制度的要求更加完整、工作手段更加完善。

三、金融行业等级保护工作的现状

等级保护1.0国家标准发布后，针对金融行业的特点，人民银行在2012年发布了针对金融行业信息系统信息安全等级保护的行业标准。此标准全部保留了国家等级保护基本要求中对二级、三级及四级系统的590项要求，并在此基础上补充细化了193项，新增了金融行业特色要求项269项，对金融行业等级保护提出了更高的要求。

新增的特色要求主要体现在以下3个方面：一是补充体系架构设计、纵深防御、信息系统生命周期管理等内容；二是结合金融行业实际安全需求与信息安全防护经验，细化补充金融行业的增强安全保护类别；三是补充了金融行业落实等级保护要求的最佳实践，以及可直接使用的等级保护测评检查表单等内容。此

行业标准的制定,对金融行业信息安全水平提出了更高的要求。

为推动等级保护工作的落实,人民银行等部门还先后发布了《中国人民银行关于银行业金融机构信息系统安全等级保护定级的指导意见》(银发〔2012〕163号)、《关于开展保险业信息系统安全等级保护定级工作的通知》(保监厅发〔2007〕45号)、《关于做好证券业重要信息系统安全等级保护定级工作的通知》(中证协发字〔2007〕117号)等文件,指导金融机构进行等级保护定级、测评等工作。以青岛辖区银行业金融机构为例,辖内地方性银行业金融机构已基本实现了等级保护工作的常态化、长效化管理,各机构基本能够自主开展等级保护定级、测评相关工作,大大推动了行业整体网络安全水平的提高。

四、金融行业落实等级保护2.0的意见和建议

在当前金融科技创新和发展的大背景下,网络安全形势日益严峻,网络威胁手段层出不穷,金融行业作为关系国计民生的重要行业,更应不断提高对网络安全工作的重视程度,做好等级保护2.0标准的贯彻与落实,提高金融行业网络安全水平。

(一)加强网络安全制度体系的学习,制定完善的网络安全管理体系

各单位应加强对网络安全制度体系的学习,深入开展针对《网络安全法》、“网络安全等级保护2.0”等相关文件标准的研究,学习先进的网络安全管理经验和要求,并不断完善自身的网络安全管理体系。各单位应研究制定涵盖安全管理制度、安全管理机构、人员安全管理、系统建设管理、系统运维管理等方面的新一代网络安全管理制度体系,不断提高网络安全管理水平。

(二)转变网络安全治理理念,不断提高网络安全治理水平

在等级保护2.0时代,传统的被动防御的理念已

经不能满足日益增长的网络安全防护的要求,各单位应该转变网络安全治理理念,变被动防御为主动防御,在入侵行为对系统产生影响之前,能够提前精准预警,实时构建弹性防御体系,避免、转移、降低系统面临的风险。同时,强化“一个中心、三重防护”的思想,建立以计算环境安全为基础,以区域边界安全、通信网络安全为保障,以安全管理中心为核心的信息安全整体保障体系,不断地提高网络安全治理水平。

(三)重视网络安全新技术的应用,持续降低网络安全风险隐患

各单位要重视网络安全新技术的应用,增强对主动防御、态势感知、可信验证、通报预警等新技术的研究和应用,强化风险的提前预警、快速处置和监督管理能力,让安全防御能力从静态转向动态,由被动转向主动,保障云计算平台、大数据平台、物联网系统、工业控制系统等新技术下的网络安全。

五、结束语

为适应新技术的快速发展,等级保护2.0在1.0的基础上进行了较大改进,基本适应了当前网络安全的要求。金融行业作为关系国计民生的重要行业,尤其在金融科技创新与发展的大背景下,要高度重视网络安全等级保护工作,进一步提高网络安全水平,不断降低网络安全风险,为国家金融行业的健康稳定发展提供安全保障。 

参考文献:

- [1] 刘宇. 对新时期金融业做好网络安全等级保护工作的思考[J]. 金融科技时代, 2018(6):72-74.
- [2] 李欣, 厚佳琪. 网络安全等级保护工作的创新发展[J]. 网络安全战略论坛, 2018(8):33-34.
- [3] 袁慧萍. 金融行业落实网络安全法的若干思考[J]. 中国信息安全, 2018(7):82-85.